

정보보호 규정



주식회사 모인

개정 이력

[illegible]

정보보호 규정

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 규정은 주식회사 모인(이하 “회사” 이라 한다)의 정보보호 관리체계를 정의하고 정보자산의 훼손, 변조 및 유출 등의 위협으로부터 회사의 정보자산 및 고객 정보를 보호하기 위해 준수해야 할 정보보안 정책을 제시하여, 정보자산을 안전하게 관리하는 것을 목적으로 한다.

제2조(적용범위) 이 규정은 회사의 임직원과 외부인력 등 출입하는 모든 사람에게 적용되며, 회사가 보유 또는 관리하고 있는 지적 재산을 포함하는 유·무형의 모든 정보자산을 보호대상으로 한다.

제3조(정책의 유지관리)

- 1 회사는 정보보호 관련 법규, 정보보호 동향, 회사 조직 또는 정보자산 등에 중대한 변화가 발생한 경우를 포함하여 정보보호 내규의 타당성을 연 1회 이상 검토하고 필요한 경우 제정, 개폐하여야 한다.
- 2 정보보호 내규는 제1항에 따라 제정, 개폐하는 경우 해당 이력이 기록되고 관리되어야 한다.

제4조(관련 법규) 회사가 준수해야 하는 정보보호 관련 법규는 「전자금융거래법」, 「개인정보 보호법」, 「신용정보의 이용 및 보호에 관한 법률」(이하 “신용정보법”이라 한다), 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 (이하 “정보통신망법”이라 한다), 「위치정보의 보호 및 이용 등에 관한 법률」 등의 정보보호에 관한 제반 법률과 그 하위법령 및 관련 감독규정·시행세칙·지침·모범규준 등을 총칭한다.

제2장 정보보호 관리체계

제1절 정보보호 조직

제5조(정보보호최고책임자)

- 1 회사는 정보기술부문 보안을 총괄하여 책임지고 정보보호 활동의 효과적인 추진을 위하여 정보보호최고책임자(이하 “CISO”라 한다)를 임명하여야 한다.
- 2 CISO는 조직의 정보보호 업무를 실질적으로 총괄할 수
- 3 있도록 정보보호 관련 지식 및 자격을 갖춘 자로서 예산, 인력 등 자원을 할당할 수 있는 권한이 있는 자로 지정하여야 한다.

제6조(정보보호 주관 부서) 회사는 CISO의 업무지원과 정보보호 활동의 체계적인 이행을 위하여 정보보호 업무 수행 조직을 구성하여야 한다.

제7조(정보보호 위원회)

- 1 회사는 정보보호 및 개인(신용)정보보호 관련 중요 사안의 심의·의결을 위하여 정보보호 위원회를 구성하고, CISO를 위원회의 위원장으로 한다.
- 2 회사는 특별한 사정이 없는 한 정보보호 위원회의 의결사항을 준수하여야 하며 의결사항의 이행에 필요한 제반비용을 충분하게 지원하여야 한다.

제8조(정보보호 조직 구성)

- 1 회사의 정보보호 조직은 정보보호의 처리에 관한 업무를 총괄할 CISO, 정보보호정책 수립 및 운영을 담당하는 정보보안팀 및 정보보호위원회로 구성한다.
- 2 정보보호 조직의 각 구성원 별 역할 및 책임은 「정보보호조직지침」 내 명시된 내용을 따른다.

제2절 인적 보안

제9조(직무 분리) 회사는 업무 권한의 오남용과 부정방지를 위하여 회사 구성원의 담당 직무를 고려하여 직무 분리 체계를 수립하여야 한다.

제10조(정보보호 준수 의무) 모든 임직원 및 외주업체 인력은 회사의 정보보호 내규를 이해하고 개인의 정보보호 의무사항을 숙지 및 성실히 이행하여야 한다.

제11조(정보보호 교육)

- 1 회사는 임직원의 정보보호 인식을 제고하고 정보보호 직무 역량의 향상을 위하여 정보보호 교육을 시행하고 지원하여야 한다.
- 2 임직원은 제1항의 정보보호 교육에 적극적으로 참여해야 한다.

제12조(인력 보안 관리) 회사는 정보보호 내규, 정보보호 관리체계의 준수사항을 위반한 임직원에 대한 처리기준을 마련하고 재발방지를 위한 대책을 수립하여야 한다.

제3절 환경 및 물리적 보안

제13조(보호 구역)

- 1 회사는 허가되지 않은 접근이나 훼손, 오용 등으로부터 회사의 시설 및 정보자산을 보호하기 위하여 물리적 보호구역을 지정하여야 한다.
- 2 제1항의 보호구역은 출입이 엄격히 통제되어야 하며 출입권한은 업무상 필요한 최소한의 인원으로 한정되어야 한다.

제14조(보호 설비) 회사는 지진, 화재 등 환경적 위협으로부터 회사의 시설 및 정보자산을 보호하기 위하여 물리적 보호설비를 운영하여야 하며 정상적 기능을 수행할 수 있도록 유지관리 하여야 한다.

제15조(업무환경 보안)

- 1 회사는 중요정보의 도난 유출 등을 예방하기 위하여 안전한 업무 수행을 위한 보안환경을 조성하여야 한다.
- 2 정보보호 주관부서는 제1항의 업무환경에 대한 보안점검을 수행하여야 한다.

제4절 정보시스템 보안

제16조(접근통제)

- 1 회사는 정보시스템의 보안사고를 방지하기 위하여 정보시스템 별로 적절한 접근통제 대책을 수립·시행하여야 한다.
- 2 회사의 접근통제 정책은 '업무상 필요한 최소한의 권한'만 해당 업무 담당자에게 허용하며, 명시적으로 허용되지 않은 전산자원에 대한 접근은 허용하지 않는 것을 원칙으로 한다.

제17조(개발보안)

- 1 시스템담당 부서는 시스템의 안전한 개발 및 보안성의 향상을 위하여, 시스템을 개발 또는 변경하려는 경우 분석부터 이관까지 개발 주기에 기반한 보호대책을 수립하여야 한다.
- 2 시스템담당 부서는 제1항의 수립된 보호대책을 정보보호 주관부서와 협의하여야 한다.

제18조(운영보안)

- 1 시스템담당 부서는 시스템의 안전한 운영과 장애 등의 문제 발생 시 적절한 대응을 위하여 시스템 운영 및 관리 방안을 수립하여야 한다.
- 2 시스템담당 부서는 허가되지 않은 접근 취약점의 노출 등으로부터 회사의 시스템을 보호하기 위하여 보호대책을 수립하여야 하며, 해당 대책은 정보보호 주관부서와 협의되어야 한다.

제19조(정보보호시스템 운영) 회사는 정보시스템의 정보보안을 강화하기 위하여 정보보호시스템(침입탐지 및 차단시스템 등)을 설치·운영 하여야 한다.

제5절 정보자산 관리

제20조(자산 식별 및 관리)

- 1 회사는 정보보호 관리체계에 포함되는 정보자산의 체계적인 관리를 위하여 적절한 분류기준을 수립하고 정보자산을 식별하여 관리하여야 한다.
- 2 정보자산은 지진, 화재 등 환경적 위협에 대비할 수 있도록 적절한 장소에 배치되어야 하며 정보자산의 적절한 취급 및 관리를 위한 보호대책을 수립하여야 한다.
- 3 비상시에 대비하여 전산자료에 대한 안전지출 및 긴급파기 계획을 수립하여야 한다.

제21조(위험관리) 회사는 정보자산의 보안 위협 발생시 영향과 발생 빈도를 분석하여 위험을 도출하고, 도출된 위험에 대해서는 보호대책을 수립하여 적용함으로써 위험을 감소시키도록 노력하여야 한다.

제6절 정보보호 사고 및 업무 연속성 관리

제22조(사고대응 체계)

- 1 회사는 정보보호 사고 및 정보시스템의 기능 장애 발생으로 인한 피해의 최소화와 회사의 가치를 보호하기 위하여 사고대응 체계를 마련하여야 한다.
- 2 회사는 이전에 발생한 정보보호 사고와 동일하거나 유사한 사고의 재발을 방지하기 위하여 재발방지 대책을 수립하여야 한다.

제23조(재해복구 계획)

- 1 회사는 천재지변, 화재, 폭동, 파업 등과 같은 비상사태의 발생에 대비하여 업무의 연속성을 확보하기 위해 IT재해복구 계획을 수립·운영하여야 한다.
- 2 회사는 IT재해복구 계획에 대한 테스트를 주기적으로 실시하여야 하며, 테스트 결과를 반영하여 재해복구 계획을 지속적으로 개선하여야 한다.

제7절 정보보호 점검 및 개선

제24조(정보보호 점검 및 내부감사) 회사는 정보보호 관리체계가 정해진 정책 및 법적 요구사항에 따라 효과적으로 운영되고 있는지 점검하기 위하여 주기적으로 정보보호 점검 및 내부감사를 수행하여야

한다.

제25조(정보보호 점검 사후관리) 회사는 정보보호 점검 및 내부감사 결과에 따라 관련파트 및 임직원에게 시정조치를 요구할 수 있으며, 관리체계상의 문제점에 대한 원인 분석 및 재발방지 대책의 수립·이행을 통해 지속적인 정보보호 관리체계 개선 활동을 수행하여야 한다.

제26조(위임) 정보보호 업무 수행을 위하여 필요한 세부적인 사항은 하위 지침에서 정한다.

부칙

제1조(시행일) 이 규정의 시행일은 대표이사가 승인한 날로 한다.